AI-GRACE: A Use-Case Operationalization Framework for Agentic AI: From Organizational Objectives and Obligations to Deployment Capabilities and Architecture

John Cuneo[1], David Chun[2], and Gaurav Khanna[3]

[1]University of Miami

[2]Columbia University

[3]Stanford University

arXiv:2609.21192v1 [cs.AI] 18 Sep 2026

Author Note

John Cuneo, ORCID: https://orcid.org/0009-0000-5372-2953; David Chun, ORCID: https://orcid.org/0009-0002-8348-3580.

The authors' account of the framework's origin and use of AI assistance appears in Appendix B.

Correspondence concerning this article should be addressed to John Cuneo. Email: cuneojn@miami.edu. Coauthor contacts: David Chun, dc4029@columbia.edu; Gaurav Khanna, gkhanna@stanford.edu.

Abstract

Organizations deploying agentic artificial intelligence must determine more than whether a model is trustworthy; they must establish what to validate, control, and observe for a use case to deliver its intended outcome while meeting applicable obligations. This paper proposes AI-GRACE (Agentic Intelligence-Governance, Risk, Assurance, Controls, and Evidence) as a use-case operationalization framework connecting organizational governance with technical implementation. The proposal draws on professional observations and a purposive synthesis of standards and literature, using design science to frame the method contribution and situational method engineering to guide contextual tailoring and reuse. The framework establishes objectives and obligations and then assesses risks in seven proposed domains, including mission and value realization. It derives requirements for assurance before deployment, runtime controls, and evidence, which guide capability qualification, gap assessment, and a logical architecture. An Agent Operating Envelope specifies permitted actions and escalation conditions, while Risk-Aligned Independence Levels (RAIL) summarize the authorized independence. A fictional retail banking application illustrates the method. The contribution is a traceable basis for deciding what an organization must implement, what it already supports, and what remains unresolved. Empirical evaluation must establish whether it improves deployment decisions, efficiency, and reuse.

Keywords: agentic AI, AI governance, use case operationalization, technical capabilities, reference architecture

AI-GRACE: A Use-Case Operationalization Framework for Agentic AI: From Organizational Objectives and Obligations to Deployment Capabilities and Architecture

An organization may want an AI assistant to improve some set of business metrics (e.g., service, complete routine requests, control operating costs). A deployment decision must establish whether the assistant can do the work well, what it can access and change, and whether existing systems can enforce the required boundaries. A risk assessment that does not reach those implementation questions leaves a critical part of the deployment problem unsolved.

Research has long identified the challenge of moving from responsible AI principles to practice (Morley et al., 2020; Papagiannidis et al., 2025). Engineering methods, governance architectures, and delegation specifications provide the foundations for this work (Arora et al., 2026; Fetzer et al., 2026; Huang et al., 2025). Deployment teams must still select, connect and qualify the capabilities required for their use case.

An agent may retrieve information, select tools, modify records, or coordinate with other agents. As an agent pursues goals with less immediate human involvement, the directness, scale, and duration of its effects can change. Human responsibility remains (Chan et al., 2023).

The same large language model can support a read-only assistant or an agent authorized to change operational records. Model evaluation alone cannot determine whether either deployment is justified. This paper asks: *How can an organization translate the objectives, obligations, and risks of an agentic AI use case into qualified technical capabilities, a logical architecture, and an accountable deployment decision?* The expected output is an implementable specification of what the organization needs, what it already has, and what remains to be resolved.

Agent capabilities describe what an agent can do. *Organizational enabling capabilities* describe what the organization can provide to deploy, evaluate, constrain, and operate it. AI-GRACE specifies a method for deriving those enabling requirements, qualifying implementations, and retaining a deployment record that supports reassessment and reuse.

RAIL summarizes the independence authorized through that assessment while the operating envelope defines the actual permissions. The objective is risk-adjusted value. A deployment with

less independence can be the appropriate outcome when it delivers the intended benefit with lower cost or exposure.

Theoretical Background and Related Work

Organizational Governance and Technical Implementation

The NIST AI Risk Management Framework organizes AI risk management through GOVERN, MAP, MEASURE, and MANAGE (National Institute of Standards and Technology [NIST], 2023). Its Playbook supplies actions that organizations select according to their circumstances (NIST, n.d.).

ISO/IEC 42001 establishes an AI management system, including objectives, risk and impact assessment, and risk treatment with a documented rationale for control selection (International Organization for Standardization & International Electrotechnical Commission [ISO/IEC], 2023, clause 6.1.3). ISO/IEC 42005 addresses impacts on people and society, including thresholds, approvals, and review (ISO/IEC, 2025, clauses 5–6). ISO/IEC 42001 also addresses resources, architecture documentation, and operational monitoring (ISO/IEC, 2023, Annex B.4 and B.6).

The Cyber Risk Institute (CRI) FS AI RMF supplies 230 control objectives with implementation guidance and illustrative controls and evidence, while distinguishing its enterprise scope from a prescription for an individual use case (CRI, 2026a, 2026b). AI-GRACE uses these resources to derive deployment requirements within the institution's existing governance arrangements.

Reuel et al. (2025) describe technical AI governance as analysis and tools for identifying governance needs, assessing interventions, and enabling enforcement or compliance. AI-GRACE addresses the organizational task of turning a proposed use case into requirements that engineering and operations can implement and assess.

Responsible Engineering as a Methodological Foundation

Fetzer et al. (2026) developed MeRGE through action design research with interviews and three realized use cases. Its method spans precheck, conceptualization, development, quality, and deployment, with an architecture containing models, orchestration, data, tools, and risk mitigation.

Testing covers functional, security, load, performance, stress, and integration requirements. MeRGE is a methodological predecessor. Its discussion identifies agentic architectures, autonomy, and translation of normative initiatives as further research directions.

AI-GRACE extends this line of work by qualifying the enabling capabilities for an agentic use case and connecting architecture, authority, and evidence to reassessment. Situational method engineering provides a basis for tailoring methods to context, supporting the proposed jurisdictional, sector, and organizational profiles (Henderson-Sellers & Ralyté, 2010).

Agentic Risk, Control Architectures, and Delegated Authority

The Agentic Risk & Capability (ARC) Framework relates components, design, and agent capabilities to contextual risks and technical controls (Khoo et al., 2025). NIST AI RMF, OWASP, MITRE ATLAS, and Cisco's Integrated AI Security and Safety Framework can inform the identification of relevant safety and security risks (Chang et al., 2025; MITRE, n.d.; NIST, 2023; OWASP Gen AI Security Project [OWASP], 2025). IMDA's agentic AI framework addresses risk boundaries, human accountability, and technical and nontechnical measures (Infocomm Media Development Authority [IMDA], 2026).

Koch (2026) connects governance objectives to enforceable controls, architectural placement, ownership, and assurance evidence. AAGATE supplies a NIST-aligned governance platform and control plane (Huang et al., 2025). These are close antecedents to AI-GRACE's implementation requirements.

Feng et al. (2025) distinguish autonomy levels through the user's role, while Zheng et al. (2026) separate autonomous capability from allowed autonomy. Arora et al. (2026) propose records for justifying agency and specifying delegated boundaries. RAIL draws on the established distinction between capability and permission to summarize the resulting authorization.

Architecture, controls, autonomy levels, and contextual assessment have these substantive antecedents. AI-GRACE makes capability qualification, service viability, and the completed deployment record central to their application.

Research Approach and Framework Construction

AI-GRACE is a prescriptive method proposal informed by design science (Gregor & Hevner, 2013; Peffers et al., 2007). Situational method engineering provides a basis for tailoring and reusing assessment activities and records according to the use case context (Henderson-Sellers & Ralyté, 2010). AI-GRACE's design proposition is that explicit links among objectives, obligations, risks, capabilities, architecture, and evidence can make deployment decisions more complete and reviewable. The fictional application demonstrates this reasoning.

The authors' professional observations identified a practical deployment problem: organizations needed to translate AI objectives and obligations into technical capabilities. They developed an initial framework, then used a purposive synthesis of governance standards, engineering methods, agentic risk frameworks, and autonomy research to refine its definitions and outputs.

The analysis uses the full texts of ISO/IEC 42001 and 42005, the NIST Playbook, CRI implementation materials, and MeRGE, supplemented by primary publications and official financial services sources. Recent preprints are treated as proposals. The banking example shows how changes in actions and authority affect obligations, capabilities, and architecture.

The seven risk domains are proposed coverage prompts, grouped around concerns that require different questions, evidence, expertise, or treatment. The assessment keeps related causes and consequences together, even when they cross domains.

The AI-GRACE Method

Unit of Assessment, Participants, and Outputs

AI-GRACE specifies the core method and outputs for assessing an AI use case in its deployment context. The assessment covers the workflow, users, affected parties, agents, models, tools, data, dependencies, and proposed authority. The use case owner and technical architect can lead the work with domain operations, engineering, security, privacy, risk, compliance, and the functions accountable for production services.

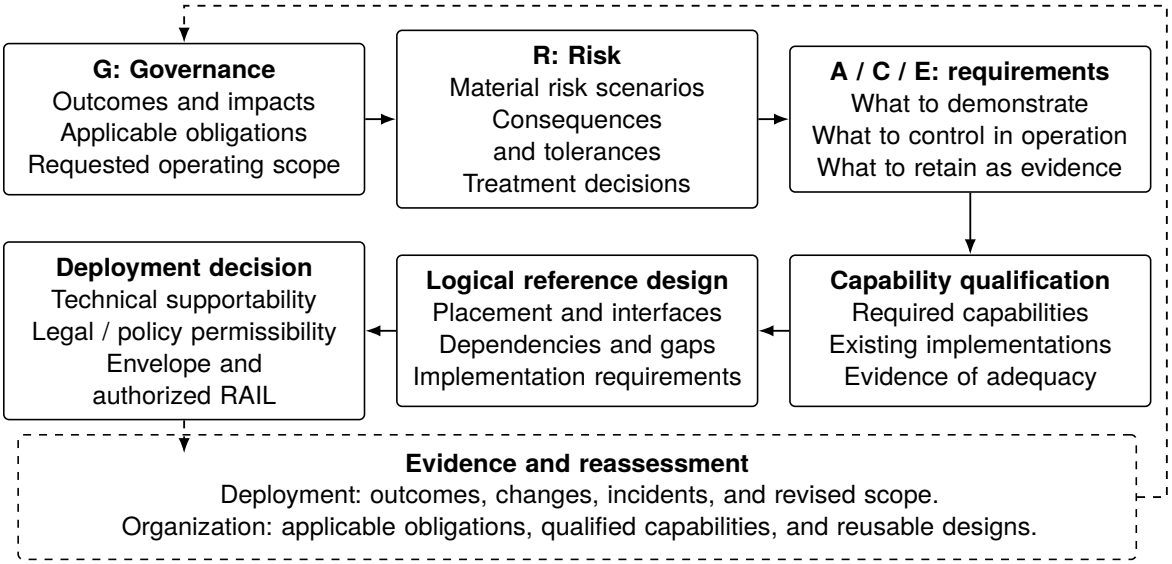
A completed assessment explains how the use case's objectives and obligations lead to a

deployment decision. It connects intended impacts and risks to required capabilities and a logical architecture, showing what the organization can support and where gaps remain. Appendix A lists the minimum record; existing organizational systems can hold its linked parts. The decision specifies an authorized operating envelope and RAIL, or withholds authorization, while recording desired and conditional future states separately.

Figure 1 shows the reasoning path. Teams revisit earlier decisions when evaluations, architectural constraints, or evidence requirements expose a problem. The method supports iteration within a use case and reuse across later assessments.

Figure 1

From Use Case Intent to a Qualified Deployment Design



Note. G = Governance; R = Risk; A = Assurance; C = Controls; E = Evidence; RAIL = Risk-Aligned Independence Levels. Dashed arrows show feedback for reassessment and reuse.

Governance: Establish the Outcome and Obligations

Governance establishes why the use case should exist and what success requires. The charter states intended outcomes and measurable acceptance conditions, then identifies affected parties and accountable owners. It sets the boundaries for proposed actions and the use of data and tools, including exclusions (ISO/IEC, 2023, clauses 4 and 6.2; NIST, 2023, MAP 1.1, 1.3–1.4). It

identifies jurisdictions and institutional roles, and a credible alternative such as conventional automation or a service delivered by people.

The obligation record distinguishes law, regulation, contract, professional duties, adopted policy, and strategic commitments. Each entry identifies its source, applicability, owner, and status. Revenue or cost objectives cannot override applicable duties or mandatory legal requirements.

Applicability depends on context: the EU AI Act requires attention to intended purpose and organizational role (Regulation (EU) 2024/1689, 2024, Articles 2, 6, 16, and 26). Impact assessment considers foreseeable benefits and harms beyond the sponsoring organization, including clients, employees, and society (ISO/IEC, 2025, clauses 6.7–6.9).

Risk: Identify What Could Defeat the Outcome

The register describes how each scenario could cause harm or prevent the intended value, identifying causes and the people or assets affected. It links the scenario to the relevant objectives and obligations and assesses likelihood and consequence under stated assumptions. The record assigns a decision owner and explains how existing measures and treatment address the risk, including residual concerns and uncertainty. Organizations can use their established scales; a risk score does not mechanically determine RAIL.

Table 1 gives seven proposed coverage domains and selected source anchors. The grouping is a design interpretation, not an endorsed taxonomy.

Table 1

Risk Domains and Selected Conceptual Anchors

Domain	Concern	Selected anchors
Mission & Value	Poor adoption, task failure, delay, resource use, or cost greater than expected benefit.	NIST MAP 1.3–1.4; CRI MP-1.4.1, MS-2.12.3
AI Behavior & Authority	Without an attacker, the agent reasons poorly, mishandles ambiguous input, selects tools incorrectly, drifts from its goal, or attempts unauthorized action.	NIST MEASURE 2.5; ARC; delegation research

Domain	Concern	Selected anchors
Safety & Human Impact	Harmful reliance, manipulation, unfair treatment, physical or psychological harm, or impaired access affects people or communities.	NIST MEASURE 2.6, 2.11; ISO/IEC 42005 clauses 6.7–6.9; Chan et al., 2023
Cybersecurity	An adversary compromises or misuses the agent, identities, data, tools, dependencies, or connected systems.	NIST MEASURE 2.7; ARC; OWASP
Privacy	Personal information is improperly collected, accessed, inferred, retained, used, transferred, or disclosed, with or without an attacker.	NIST MEASURE 2.10; ISO/IEC 42005
Operational Resilience	Availability, latency, capacity, recovery, dependencies, or maintainability cannot sustain the required service.	NIST MEASURE 2.3, 2.7; ISO/IEC 42001 Annex B.6.2.6; MeRGE quality phase
Legal, Regulatory & Policy	The use case or its operation fails to satisfy an applicable obligation.	NIST GOVERN 1.1; ISO/IEC 42001 clause 6.1.3; CRI GV-1.1.1

Note. NIST = National Institute of Standards and Technology (AI RMF 1.0, 2023); CRI = Cyber Risk Institute (Control Objective Reference Guide, 2026b); ISO/IEC = International Organization for Standardization/International Electrotechnical Commission (42001, 2023; 42005, 2025). ARC = Agentic Risk & Capability Framework (Khoo et al., 2025); OWASP = Open Worldwide Application Security Project (OWASP, 2025). Delegation research refers to Feng et al. (2025), Zheng et al. (2026), and Arora et al. (2026); MeRGE refers to Fetzer et al. (2026).

One failure can span domains: goal hijacking may exploit an authorization defect, expose private data, and cause financial loss. Retain that causal chain as one linked scenario rather than several independent events. A primary domain supports ownership; dependencies remain distinguishable from impacts, and concerns that fit poorly remain visible. Resource cost falls under resilience when it threatens continued service and under Mission & Value when it defeats the economic objective.

Assurance: Specify What Must Be Demonstrated

Assurance specifies evaluations needed before deployment or material change. This is AI-GRACE's operational distinction; broader assurance guidance covers trustworthiness across development and deployment (Department for Science, Innovation and Technology [DSIT], 2024). An assurance requirement states the claim, test method, acceptance criterion, population, workload, version, and treatment of uncertainty.

Tests address the assembled system and its intended controls, covering task quality, agent behavior, tool use, security, privacy, human impact, resilience, scale, and economics as relevant (CRI, 2026b, MS-2.1.1–MS-2.1.2, MS-2.3.4, MS-2.5.1, MS-2.12.3; NIST, 2023, MEASURE 2.1, 2.3–2.7, 2.10–2.11). Tests must exercise the actual integration path. An aggregate accuracy score can obscure a small but unacceptable set of errors.

Changes in actions or authority require corresponding evaluation, not a universal test suite for each RAIL. Failed assurance can lead to redesign, stronger controls, reduced scope, or a decision not to deploy.

Controls: Constrain and Sustain Operation

ISO/IEC 42001 and NIST use controls broadly, including organizational policies and procedures (ISO/IEC, 2023, clause 3.21; NIST, 2023, GOVERN 1.4). AI-GRACE's Controls function focuses on technical mechanisms that enforce boundaries and sustain service. For example, a policy restricts access to protected data. Then identity-based authorization enforces that restriction when the agent requests data or invokes a tool.

Controls include guardrails, trusted tool interfaces, identity and authorization, approval workflows, action limits, resource budgets, isolation, failover, and revocation. A guardrail inspects inputs, outputs, or tool calls and blocks, modifies, or escalates activity against a policy. Its detection may be imperfect. So, consequential prohibitions should, where feasible, also be enforced independently of the agent's interpretation.

Control placement follows the execution path. Input inspection addresses untrusted content, orchestration limits trajectories and budgets, data services enforce access scope, and execution

services constrain consequential actions. Each control specifies its condition, location, required identity and state, dependencies, owner, failure behavior, and evidence. Teams must justify each additional control layer's latency, cost, complexity, and failure modes against the service objective.

Evidence: Retain the Basis for Reliance

Evidence connects deployment decisions to evaluations and operational outcomes. It includes risk decisions, versions, control tests, approvals, observable actions, and business and service results, linked to the requirements they substantiate (CRI, 2026b, MS-2.4.1–MS-2.4.3; NIST, 2023, MEASURE 2.4; MANAGE 4.1). For a consequential action, the record links the principal and agent to the request and its authorization under a specified mandate and policy version. It retains relevant provenance, distinguishes what was attempted from what was committed, and records the outcome.

The evidence design distinguishes an agent's account of an action from the authoritative execution record. Collection remains proportionate to purpose, with access controls, integrity protection, retention periods, and justified sampling. AI-GRACE does not require hidden model reasoning or indiscriminate retention of sensitive data.

Detailed interaction capture can aid diagnosis: Langfuse supports tracing prompts, responses, tool and retrieval steps, timing, and metadata (Langfuse, n.d.). A team adopting such capture must qualify its privacy, access, and retention properties. Critical action records may need different availability and retention from aggregate quality monitoring.

Derive and Qualify the Enabling Capabilities

A capability requirement specifies what must hold, where, and how adequacy will be demonstrated. The derivation procedure is:

1. Select an objective, obligation, or material risk and state the required outcome.
2. Specify what must be demonstrated before reliance, constrained during operation, and retained as evidence.
3. Identify the technical capabilities and supporting services needed.
4. Define acceptance criteria, scope, interfaces, dependencies, owners, and architectural

placement.

5. Assess candidate implementations and record gaps or justified alternatives.

Requirements can originate directly in objectives or obligations. One service can support several A/C/E requirements, and one requirement can depend on several services. Model serving, storage, connectivity, capacity, isolation, and recovery are enabling capabilities whose required properties follow from the use case.

For each candidate implementation, record one of four fit states:

Sufficient.

Evidence demonstrates adequacy within the stated scope, version, workload, and dependencies.

Partially sufficient.

Some required properties are demonstrated, but identified limitations remain.

Absent.

No implementation of the required capability is available.

Not yet demonstrated.

A candidate exists, but has not been evaluated.

Owning an evaluation tool does not demonstrate that it can evaluate this use case, or that this agent passed its evaluations. Prior qualification applies only where its conditions still hold. The gap record names the unmet requirement, responsible owner, closure evidence, dependencies, alternatives, and effect on deployment. Missing legal permission or accountability remains a separate constraint.

Realize the Requirements in a Logical Architecture

The logical design places capabilities along the workflow: principals, agent and model services, data access, consequential actions, enforcement points, evidence paths, and infrastructure. Each capability has a location or an unresolved gap, and each material control links to its assessment basis. ISO/IEC 42001's resource and technical documentation provisions provide relevant foundations (ISO/IEC, 2023, Annex B.4 and B.6.2.7).

Review whether identity and access scope survive delegation, required approval precedes execution, retries avoid duplicate or inconsistent effects, dependencies support recovery, and evidence can be reconciled. Assess the cost and latency of the complete design. An approved target architecture supports engineering. Deployment readiness requires evidence that the implemented configuration satisfies it. Product selection, bills of materials, and code follow from that design.

Determine Authority and Summarize It With RAIL

Deployment requires demonstrated technical support, permission under applicable law, contract, and organizational policy, and an accountable decision accepting residual risk and the operating arrangements. None of these conditions establishes the others. A requested operating envelope does not establish authorization.

The decision covers the whole operating envelope, including concurrent actions, their sequence, aggregate exposure, and dependencies. If no acceptable envelope remains, deployment is not authorized. An organization may authorize less than it could technically support.

The Agent Operating Envelope defines permitted and prohibited actions and any required approvals within a specified scope of accounts, data, tools, and counterparties. It sets operational limits and mandate duration, bounds resource use, and specifies escalation and revocation conditions. Organizational deployment authorization and any required consent from affected parties remain distinct. Recommendations can have consequential effects even without execution.

Table 2 summarizes authorized independence. The envelope remains authoritative; RAIL is not a maturity rating, capability score, or measure of risk.

Table 2

Risk-Aligned Independence Levels

Level	Label	Authorized behavior
0	Assist	Retrieve, summarize, or present information within scope; no mandate to recommend a course of action or execute consequential external actions.
1	Recommend	Analyze and recommend; a human decides and performs consequential external actions.

Level	Label	Authorized behavior
2	Act with Approval	Each consequential external action requires explicit human approval. Scoped retrieval, reasoning, and preparation do not require approval at every step.
3	Bounded Autonomous	Execute a defined class of consequential actions within an approved mandate without individual approval; escalate at defined boundaries.
4	High-Authority Autonomous	Coordinate broader approved tasks or mandates under supervision rather than routine approval of individual consequential actions. All activity remains bounded.

Mixed workflows retain conditions for each action. RAIL classification follows the approved behavior and scope of each action. A higher level does not permit an agent to expand its own privileges. If the requested scope cannot be supported, the assessment records the gap and available alternatives.

Reassess the Use Case and Reuse Qualified Patterns

Profiles organize context through core, jurisdiction, industry, organization, and use case, consistent with NIST's contextual tailoring (NIST, 2023, section 6). For example, industry profiles can include financial services, healthcare, higher education, defense, and critical infrastructure. Their baseline Governance and Risk inputs would cover obligation references, governance expectations, affected parties, and recurring scenarios. Developing and evaluating these profiles remains future work.

Within a deployment, changed behavior, cost, obligations, data, models, tools, dependencies, scale, or authority triggers targeted reassessment. A protective response may narrow or suspend activity. Expansion requires a new decision. An absence of incidents is meaningful only where detection and evidence collection could reveal failures.

Across use cases, teams can reuse applicable assessments, qualified capabilities, architectures, and evidence after checking scope and currency. Shared dependencies, capacity contention, correlated failures, and combined permissions may require assessment across deployments. Reuse does not transfer RAIL or authorization.

Illustrative Application: A Personal Banking Assistant

A fictional banking group proposes a personal banking assistant for its U.S. national bank and EU credit institution. Conventional banking infrastructure exists, but no assistant is deployed or authorized. The service would explain accounts and spending, review bills, and arrange client-approved payments.

The scenario assumes full applicability of the EU AI Act and DORA to the relevant entities and activities after the applicable dates. Obligations, starting capabilities, risk judgments, and acceptance conditions are illustrative assessment inputs. Tables 3–6 trace the proposal through governance, risk, A/C/E requirements, and capability qualification.

Governance: Establish the Service and Applicable Obligations

The service owner seeks correct task completion with less client effort and sustainable total cost, compared with conventional digital banking and human assistance. “Explain my electricity bill and help me pay it” must end with a correct explanation and, if the client proceeds, the payment they approved. Pending payments, unresolved conversations, and repeat calls to correct errors do not count as successful completion.

Scope includes authenticated clients, authorized accounts, approved bank information, bills, and existing payment services. Creditworthiness decisions, credit scoring, product eligibility, and investment trading are excluded. The EU entity is assumed to provide the system under its own name and use it, requiring assessment of provider and deployer responsibilities; intended purpose determines classification (Regulation (EU) 2024/1689, 2024, Articles 3 and 6). This assumption does not make every banking assistant high-risk.

Table 3

Governance Inputs and Required Outcomes

ID	Source and applicability	Required outcome
G1	Bank service charter: organizational objectives and commitments.	Correct completion, accessible human recourse, fewer interactions, and sustainable total cost, including failures and rework.
G2	EU AI Act: Article 5(1)(a)–(b) prohibitions; Article 50(1), (5) AI interaction notice; Article 50(2) marking of generated content; recital 27's nonbinding principles (Regulation (EU) 2024/1689, 2024).	Prevent prohibited manipulation or exploitation meeting the Act's conditions; identify AI interaction. Record Article 50(2) applicability and any required marking of generated content. The bank adopts oversight, safety, fairness, and accountability as service requirements, including for vulnerable clients.
G3	GDPR Article 5: lawful processing, purpose limitation, minimization, security, accountability (Regulation (EU) 2016/679, 2016).	Constrain account access, retrieval, memory, model disclosure, and telemetry to the approved purpose; demonstrate these boundaries.
G4	U.S. national bank: Gramm–Leach–Bliley Act safeguards through 12 CFR part 30, Appendix B, II–III (Interagency Guidelines, 2026).	Extend customer information safeguards to the agent, tools, and suppliers: threat assessment, access restrictions, protection, testing, and incident response.
G5	EU credit institution: DORA Articles 8, 11, 17–19, 24–25, 28–30 (Regulation (EU) 2022/2554, 2022).	Map dependencies; test continuity and recovery; investigate and report qualifying ICT incidents through bank processes; assess suppliers and contracts.
G6	U.S. Regulation E, 12 CFR 1005.11; national implementation of PSD2 Articles 64, 97–98 (Directive (EU) 2015/2366, 2015; Procedures for Resolving Errors, 2026).	Preserve consent and applicable authentication, including transaction linking where required; reconstruct errors and disputes. The chosen design requires client approval of each payment alongside existing bank checks.

Note. G identifies Governance inputs. EU = European Union; GDPR = General Data Protection Regulation; CFR = Code of Federal Regulations; DORA = Digital Operational Resilience Act; ICT = information and communication technology; PSD2 = Second Payment Services Directive.

Compliance owns the applicability record, including national implementation and the distinction between binding provisions and adopted principles. Service, privacy, security, payments,

and operations owners translate these obligations into technical requirements. Any required marking under Article 50(2) enters A1 tests, C1 output processing, and E1's configuration and evaluation records (Table 5).

Risk: Identify the Failure Paths That Matter

Table 4 covers ordinary failures and malicious influence. For this greenfield workflow, release decisions depend on consequences and acceptance criteria.

Table 4

Risks Linked to Governance Inputs and Treatment Decisions

Risk / governance link	Failure and consequence	Required property and owner
R1: AI Behavior & Authority; G1, G6	Invented balances, misread bills, wrong tools, or false completion produce incorrect advice or payment.	Ground answers and verify outcomes; service/payments owners require critical task and action tests.
R2: Mission & Value; G1	Repeated calls and unresolved tasks increase cost and client effort.	Measure quality and total cost per resolved task; service owner rejects failure to meet value criteria.
R3: Cybersecurity; G2, G4, G5	Injected bill content or compromised tools redirect the agent toward theft or altered payments.	Security owner requires adversarial tests, tool assessment, and independent enforcement.
R4: Privacy; G3, G4	Retrieval, memory, model requests, or traces expose another client's data or retain excess information.	Privacy owner requires client/entity isolation, limited collection, and access/leakage tests across data paths.
R5: Operational Resilience; G5, G6	Model/tool failure stalls requests; retries duplicate payments or lose their status.	Operations owner requires consistent recovery, reconciliation, fallback, and workload/failure tests.
R6: Safety & Human Impact; G1, G2	Manipulative guidance, harmful reliance, unequal service, or inaccessible assistance harms clients.	Service owner requires tests by affected group, safe responses, and recourse; critical harm blocks release.
R7: Legal, Regulatory & Policy; G2–G6	Missing disclosures, bypassed consent, mishandled incidents, or crossed service/entity boundaries breach obligations.	Compliance records permissibility; deployment authority reviews remaining gaps and evidence of enforcement.

Note. R identifies risk scenarios; G identifies the linked Governance inputs in Table 3.

Malicious instructions in a bill can redirect the agent, exploit an access-control weakness,

and expose account data or cause an incorrect payment; these consequences belong to one linked scenario. R1 can cause an incorrect payment without an attacker. An accurate answer may still be manipulative or unsuitable under R6, so quality, safety, and security require different demonstrations.

Assurance: Derive the Technical Evaluation Capabilities

Table 5 derives the technical specification. R7 spans these chains through the applicable obligations. The design uses the Model Context Protocol (MCP) for selected tool connections.

Table 5

Linked Assurance, Control, and Evidence Capabilities

Risk basis	Assurance: before release or change	Controls: runtime enforcement	Evidence: tests and outcomes
R1, R2, R6; G1–G2	**A1 Agent evaluations.** Banking tasks: correctness, tool choice, completion, harmful advice, group differences, handoff, effort, cost.	**C1 Quality and safety guardrails.** Grounding, output checks, scope limits, AI notice, human recourse.	**E1 Agent tracing and outcome review.** Model/tool spans, sources, outputs, resolution, correction, handoff, cost; linked evaluation versions.
R3, R6; G2, G4–G5	**A2 Red teaming and MCP scanning.** Model/agent attacks, injected content, tool descriptions, servers, permissions, dependencies.	**C2 Runtime inspection.** Inspect input, output, and tool results; permit only approved tool and server versions; contain or escalate suspicious activity.	**E2 Security and safety findings.** Test cases, scanner coverage, findings and disposition, guardrail events, policy versions, incidents.
R4; G3–G4	**A3 Access and privacy tests.** Client/agent/entity permissions, session isolation, leakage, telemetry minimization.	**C3 Identity-based enforcement.** Scoped credentials, authorization at tool/data boundaries, isolated memory, protected/redacted telemetry.	**E3 Access decisions.** Principal, resource, policy, permit/deny result, retention/access configuration; exclude unnecessary payloads.

Risk basis	Assurance: before release or change	Controls: runtime enforcement	Evidence: tests and outcomes
R1, R3, R5; G6	**A4 Payment integration tests.** Approval tampering, revocation, replay, timeout, reconstruction through execution.	**C4 Transaction enforcement.** Approval bound to exact details; independent gate, durable duplicate suppression, reconciliation.	**E4 Payment evidence.** Proposal, client approval, authorization, committed transaction, reconciled status; linked identifiers.
R5, R2; G1, G5	**A5 Resilience and load tests.** Outages, capacity, recovery, telemetry loss, incident routing.	**C5 Operational constraints.** Timeouts, retry/step/cost limits, circuit breakers, recoverable state, payment holds, fallback.	**E5 System observability.** Correlated logs, traces, metrics, dependency health, service objectives, incidents, recovery results.

Note. A = Assurance; C = Controls; E = Evidence; MCP = Model Context Protocol. G and R refer to the linked inputs and risks in Tables 3 and 4.

Domain experts review A1 tasks against conventional service: resolution quality must not degrade, interactions must decrease, and total cost per resolved request must not increase, including failed attempts and correction. Critical cases cover wrong accounts, payees, or amounts; false completion; harmful guidance; and failed handoff. Each must meet its expected outcome, with results reviewed by task and affected client group.

A2 uses red teaming to test how the model and assembled agent respond to attacks. MCP scanning checks selected servers and their metadata, covering configurations and dependencies as well as permissions. MCP guidance identifies risks involving authorization and trust boundaries (Model Context Protocol contributors [MCP contributors], 2025). Scans cover only their stated checks and require targeted execution tests; safe model responses alone do not establish safe tool use.

Under A3–A5, a changed payee after approval must be rejected, and a timeout after commitment must trigger reconciliation rather than another payment. Release requires a qualified evaluation process and evidence that the actual configuration passed, with versions, coverage, failures, and residual uncertainty recorded.

Controls: Place Enforcement on the Runtime Paths

C1/C2 inspect client requests, retrieved content, tool results, and responses. Detection remains imperfect; staying on topic does not establish correctness. C3 independently enforces access restrictions at the gateway and downstream service, using verifiable client and agent identities, entity context, account scope, and the requested data and action. It also isolates sessions and limits model context to what the task requires.

For C4, the client reviews canonical details in the trusted bank interface. Approval binds principal, entity, account, payee, amount, currency, execution date, and validity conditions; the execution service checks the record and current policy before commitment. Changed details require new approval, and the agent has no bypass credential.

C5 holds ambiguous payments for reconciliation, caps repeated work, and routes unresolved requests to human service. Loss of a required payment control or durable action record blocks new commitments.

Evidence: Connect Agent Behavior to Service and System Outcomes

The collector correlates agent spans, control decisions, system logs, metrics, and backend outcomes. A “payment sent” trace must join to the authoritative payment result before it supports completion. E1–E5 also retain evaluations, versions, approvals, and release decisions, subject to access, redaction, retention, and integrity controls.

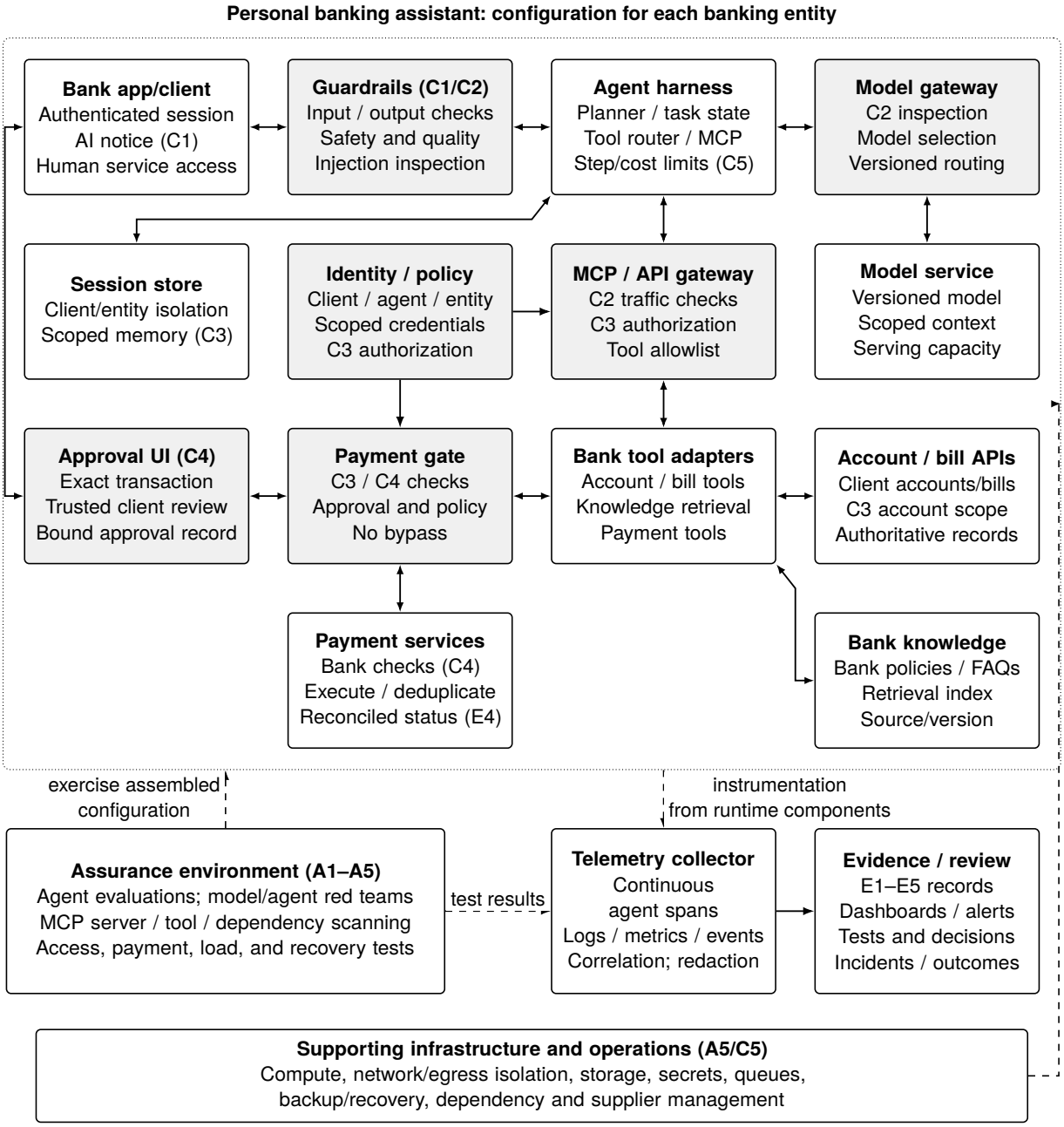
Quality sampling cannot discard required payment records. Report unresolved outcomes explicitly. Token estimates alone do not establish total service cost. Production traces can inform renewed evaluations without replacing assurance before release.

Architecture: Assemble the Agent and Its Enabling Services

Figure 2 places the capabilities in the agent’s request, model, data, and execution paths. The harness maintains task state, calls the model, selects tools, and prepares responses or actions; account and bill APIs remain authoritative. Assurance exercises these interfaces, while runtime instrumentation feeds observability and retained evidence. EU and U.S. deployments use their own policy, data, and supplier configurations.

Figure 2

Target Architecture for the Greenfield Banking Assistant



Note. Solid arrows show service and tool paths; dashed arrows connect assurance, telemetry, and infrastructure. A = Assurance; C = Controls; E = Evidence; MCP = Model Context Protocol; API = application programming interface; UI = user interface; FAQ = frequently asked question. A1–A5, C1–C5, and E1–E5 refer to Table 5.

Capability Qualification and the Deployment Decision

Table 6 assesses assumed bank capabilities against the new assistant's requirements. Prior qualification of a banking service grants no assistant access by itself.

Table 6

Capability Fit and Required Delivery Work

Candidate capability	Illustrative fit	Required work and owner
Bank identity, read APIs, payment services	Existing bank services: sufficient. Assistant integration: not yet demonstrated.	Architecture/security owners verify the new agent and delegation paths.
Agent evaluations, red teaming, MCP scanning, access/privacy tests, payment integration tests (A1–A4)	Absent for this use case	Evaluation/security owners establish tasks, attacks, assessments, and acceptance evidence.
Runtime guardrails, agent access and approval enforcement (C1–C4)	Absent at agent boundary	Engineering/security/payments owners add inspection, scoped authorization, approval binding, and execution mediation; qualify through A1–A4.
Central logging and bank transaction records (E1–E5)	Partially sufficient	Observability/evidence owners add continuous tracing, correlated decisions, protected retention, outcome links, and incident integration; test reconstruction and collection failure.
Hosting, model serving, recovery, suppliers (A5/C5)	Not yet demonstrated for design	Platform/operations owners establish capacity, dependency, recovery, and supplier evidence.

Note. A = Assurance; C = Controls; E = Evidence; API = application programming interface; MCP = Model Context Protocol. Identifiers refer to Table 5.

The current decision authorizes engineering and evaluation, with no assistant deployment yet authorized. Release requires technical gap closure, acceptable value and residual risk, and recorded legal/policy permissibility for each entity.

If qualified and authorized, retrieval and preparation can proceed within account scope while each payment requires client approval: RAIL 2. The envelope fixes tools, payees, existing bank transaction limits, approval expiry, resource budgets, entity/data boundaries, escalation, and revocation. Scoped reads and model calls need no separate approval.

Reassessment and Reuse When the Service Changes

A new bill source reopens provenance, MCP/tool configuration, injection, privacy, supplier, and quality checks under A1–A3/A5. Approval and payment evidence patterns can be reused if the execution path is unchanged; the source remains outside the envelope until gaps close. Rising cost per resolved task reopens R2, C5 budgets, and A1 evaluation without necessarily changing payment authority.

Delegated wealth activity requires an updated charter and applicable investment permissions, considering U.S. fiduciary interpretation and robo-adviser staff guidance where relevant (U.S. Securities and Exchange Commission [SEC], 2019; U.S. Securities and Exchange Commission, Division of Investment Management [SEC], 2017). Excessive equities trading volume could arise from malicious influence, poor reasoning, a misaligned objective, or an uneconomic strategy. Assurance adds mandate and market stress tests; controls add instrument, exposure, turnover, validity, and cost limits; evidence links positions, client costs, exceptions, and supervision. Historical simulation does not establish future performance, and transaction revenue does not establish client value.

A bounded investment mandate may support RAIL 3 after separate authorization. Broader coordination may require RAIL 4 and combined constraints (investment activity must not consume liquidity reserved for an approved bill). Identity, tracing, and execution patterns may be reusable, but mandates, tests, and authorization are not inherited.

Discussion

Value, Proportionality, and Reuse

AI-GRACE keeps service value visible when selecting technical capabilities, consistent with NIST and CRI's attention to business value and resources (CRI, 2026a; NIST, 2023). Teams

must compare the cost and effects of controls with the intended outcome while meeting mandatory obligations. Reuse may reduce repeated work, but maintaining qualifications, dependencies, and shared services also creates cost.

Limitations

AI-GRACE has not been empirically validated. The purposive source selection and fictional application support its design rationale, but do not show whether the method improves deployment decisions. The coverage of the seven risk domains and the reliability of capability fit judgments require independent evaluation.

Assessment quality depends on the available evidence and the assessors' judgment. Incomplete evidence, missed risks, or implementation defects can leave a deployment exposed despite a completed assessment. Shared platforms and interacting agents may also create effects beyond an individual assessment's scope.

Initial studies should compare AI-GRACE with established organizational practice informed by relevant standards, using matched deployment cases and independent review of missed requirements, unsupported capability judgments, architecture consistency, and assessment effort. Field studies should examine implementation rework, operating outcomes, and reuse. A justified decision to narrow or reject deployment should count as a useful outcome. Further work should develop and evaluate industry profiles and test assessments across interacting deployments.

Conclusion

Organizations deploying agentic AI commit resources and accept responsibility for systems that can affect people, data, and operations. They need to establish whether the proposed use case can deliver value, meet its obligations, and operate within enforceable boundaries. Authorizing deployment without a structured assessment of those conditions would place the organization and its stakeholders at risk.

AI-GRACE connects those responsibilities to the technical capabilities and architecture an organization must put in place. It identifies what the organization can already support, what remains unresolved, and the evidence needed to justify deployment. Organizations need AI-GRACE or an

equivalent method to connect governance commitments to implementation and remain accountable for the scope they authorize. The purpose is to pursue risk-adjusted value while retaining a basis for reassessment and reuse.

References

Arora, C., Vogelsang, A., & Sharma, A. (2026). *Specifying the delegated-autonomy boundary: Requirements engineering for agentic AI* [Preprint, arXiv:2607.17225v1]. arXiv. https://doi.org/10.48550/arXiv.2607.17225

Chan, A., Salganik, R., Markelius, A., Pang, C., Rajkumar, N., Krasheninnikov, D., Langosco, L., He, Z., Duan, Y., Carroll, M., Lin, M., Mayhew, A., Collins, K., Molamohammadi, M., Burden, J., Zhao, W., Rismani, S., Voudouris, K., Bhatt, U., . . . Maharaj, T. (2023). *Harms from increasingly agentic algorithmic systems* [Preprint, arXiv:2302.10329v2]. arXiv. https://doi.org/10.48550/arXiv.2302.10329

Chang, A., Saade, T., Mendapara, S., Swanda, A., & Garg, A. (2025). *Cisco integrated AI security and safety framework report* [Preprint, arXiv:2512.12921v1]. arXiv. https://doi.org/10.48550/arXiv.2512.12921

Cyber Risk Institute. (2026a). *The CRI financial services AI risk management framework: Guidebook* (Version 1.0). https://cyberriskinstitute.org/artificial-intelligence-risk-management/

Cyber Risk Institute. (2026b). *Financial services AI risk management framework: Control objective reference guide* (Version 1.0). https://cyberriskinstitute.org/artificial-intelligence-risk-management/

Department for Science, Innovation and Technology. (2024, February 12). *Introduction to AI assurance*. https://www.gov.uk/government/publications/introduction-to-ai-assurance/introduction-to-ai-assurance

Directive (EU) 2015/2366 of 25 November 2015 on payment services in the internal market, 2015 O.J. (L 337) 35 (2015). https://eur-lex.europa.eu/legal-content/EN/TXT/HTML/?uri=CELEX:32015L2366

Feng, K. J. K., McDonald, D. W., & Zhang, A. X. (2025). *Levels of autonomy for AI agents* [Preprint, arXiv:2506.12469v2]. arXiv. https://doi.org/10.48550/arXiv.2506.12469

Fetzer, D., Gimpel, H., Meindl, O., & Strickmann, J. (2026). Responsible engineering of

information systems based on generative artificial intelligence: An action design research study at a German premium car manufacturer. *Business & Information Systems Engineering, 68*(3), 583–608. https://doi.org/10.1007/s12599-025-00950-6

Gregor, S., & Hevner, A. R. (2013). Positioning and presenting design science research for maximum impact. *MIS Quarterly, 37*(2), 337–355. https://doi.org/10.25300/MISQ/2013/37.2.01

Henderson-Sellers, B., & Ralyté, J. (2010). Situational method engineering: State-of-the-art review. *Journal of Universal Computer Science, 16*(3), 424–478. https://doi.org/10.3217/jucs-016-03-0424

Huang, K., Lambros, K. R., Huang, J., Mehmood, Y., Atta, H., Beck, J., Narajala, V. S., Baig, M. Z., Ul Haq, M. A., Shahzad, N., & Gupta, B. (2025). *AAGATE: A NIST AI RMF-aligned governance platform for agentic AI* [Preprint, arXiv:2510.25863v2]. arXiv. https://doi.org/10.48550/arXiv.2510.25863

Infocomm Media Development Authority. (2026, January). *Factsheet: Model AI governance framework for agentic AI*. https://www.imda.gov.sg/-/media/imda/files/news-and-events/media-room/media-releases/2026/01/factsheet-model-ai-governance-framework-for-agentic-ai.pdf

Interagency Guidelines Establishing Information Security Standards, 12 C.F.R. pt. 30, app. B (2026). https://www.ecfr.gov/current/title-12/chapter-I/part-30/appendix-Appendix%20B%20to%20Part%2030

International Organization for Standardization & International Electrotechnical Commission. (2023). *Information technology – Artificial intelligence – Management system* (ISO/IEC Standard No. 42001:2023). https://www.iso.org/standard/42001

International Organization for Standardization & International Electrotechnical Commission. (2025). *Information technology – Artificial intelligence (AI) – AI system impact assessment* (ISO/IEC Standard No. 42005:2025). https://www.iso.org/standard/42005

Khoo, S., Foo, J., & Lee, R. K.-W. (2025). *With great capabilities come great responsibilities:*

Introducing the agentic risk & capability framework for governing agentic AI systems [Preprint, arXiv:2512.22211v1]. arXiv. https://doi.org/10.48550/arXiv.2512.22211

Koch, C. (2026). *From governance norms to enforceable controls: A layered translation method for runtime guardrails in agentic AI* [Preprint, arXiv:2604.05229v1]. arXiv. https://doi.org/10.48550/arXiv.2604.05229

Langfuse. (n.d.). *Observability & application tracing*. Retrieved September 14, 2026, from https://langfuse.com/docs/observability/overview

MITRE. (n.d.). *MITRE ATLAS*. Retrieved September 12, 2026, from https://atlas.mitre.org/

Model Context Protocol contributors. (2025). *Security best practices* (Version 2025-11-25). Model Context Protocol. https://modelcontextprotocol.io/specification/2025-11-25/basic/security_best_practices

Morley, J., Floridi, L., Kinsey, L., & Elhalal, A. (2020). From what to how: An initial review of publicly available AI ethics tools, methods and research to translate principles into practices. *Science and Engineering Ethics, 26*, 2141–2168. https://doi.org/10.1007/s11948-019-00165-5

National Institute of Standards and Technology. (n.d.). *AI RMF playbook*. Retrieved September 12, 2026, from https://airc.nist.gov/airmf-resources/playbook/

National Institute of Standards and Technology. (2023). *Artificial intelligence risk management framework (AI RMF 1.0)* (NIST AI 100-1). https://doi.org/10.6028/NIST.AI.100-1

OWASP Gen AI Security Project. (2025, December 9). *OWASP top 10 for agentic applications for 2026*. https://genai.owasp.org/resource/owasp-top-10-for-agentic-applications-for-2026/

Papagiannidis, E., Mikalef, P., & Conboy, K. (2025). Responsible artificial intelligence governance: A review and research framework. *Journal of Strategic Information Systems, 34*(2), Article 101885. https://doi.org/10.1016/j.jsis.2024.101885

Peffers, K., Tuunanen, T., Rothenberger, M. A., & Chatterjee, S. (2007). A design science research methodology for information systems research. *Journal of Management Information Systems, 24*(3), 45–77. https://doi.org/10.2753/MIS0742-1222240302

Procedures for resolving errors, 12 C.F.R. § 1005.11 (2026). https://www.consumerfinance.gov/rules-policy/regulations/1005/11/

Regulation (EU) 2016/679 of 27 April 2016 (General Data Protection Regulation), 2016 O.J. (L 119) 1 (2016). https://eur-lex.europa.eu/legal-content/EN/TXT/HTML/?uri=CELEX:32016R0679

Regulation (EU) 2022/2554 of 14 December 2022 on digital operational resilience for the financial sector, 2022 O.J. (L 333) 1 (2022). https://eur-lex.europa.eu/eli/reg/2022/2554/oj

Regulation (EU) 2024/1689 of 13 June 2024 laying down harmonised rules on artificial intelligence (Artificial Intelligence Act), 2024 O.J. (L 2024/1689) (2024). https://eur-lex.europa.eu/eli/reg/2024/1689/oj/eng (Consolidated text, July 27, 2026: https://eur-lex.europa.eu/eli/reg/2024/1689/2026-07-27/eng).

Reuel, A., Bucknall, B., Casper, S., Fist, T., Soder, L., Aarne, O., Hammond, L., Ibrahim, L., Chan, A., Wills, P., Anderljung, M., Garfinkel, B., Heim, L., Trask, A., Mukobi, G., Schaeffer, R., Baker, M., Hooker, S., Solaiman, I., . . . Trager, R. (2025). Open problems in technical AI governance. *Transactions on Machine Learning Research*. (arXiv:2407.14981v2). https://doi.org/10.48550/arXiv.2407.14981

U.S. Securities and Exchange Commission. (2019). *Commission interpretation regarding standard of conduct for investment advisers* (Release No. IA-5248). https://www.sec.gov/files/rules/interp/2019/ia-5248.pdf

U.S. Securities and Exchange Commission, Division of Investment Management. (2017, February). *Robo-advisers* (IM Guidance Update No. 2017-02). https://www.sec.gov/files/im-guidance-2017-02.pdf

Zheng, H., Dong, Q., Depena, R. K., Bhatia, J. D., Xiao, F., & Xu, P. (2026). *Separating capability from permission: A governance framework for agentic AI autonomy levels* [Preprint, arXiv:2607.23438v1]. arXiv. https://doi.org/10.48550/arXiv.2607.23438

Appendix A

Minimum Deployment Record

Table A1 specifies linked information, not separate mandatory documents. Existing organizational systems can hold these records, with owners, versions, approval status, and review dates or triggers.

Table A1

Minimum Content of an AI-GRACE Assessment

Record	Required content
Use case charter	Objectives, impacts, comparator, acceptance conditions, affected parties, organizational and affected-party roles, workflow, data, tools, actions, exclusions.
Obligation register	Source and locator; legal, contractual, policy, or strategic status; applicability, jurisdiction, owner, requirements, conflicts, unresolved decisions.
Risk register	Scenario, causes, primary/linked domains, affected objectives and parties, likelihood, consequences, assumptions, uncertainty, treatment, residual risk, decision owner.
Capability requirement	Identifier, linked objective/obligation/risk, A/C/E function, scope, acceptance criterion, evidence method, placement, interfaces, dependencies, owner.
Capability fit	Candidate implementation/version, fit state, supporting evidence, qualification scope, limitations, required changes or validation.
Logical design	Agent/services, principals, data and execution paths, enforcement, evaluations, evidence, infrastructure, requirement links, gaps.
Operating envelope	Allowed and prohibited activity, required approvals; accounts, data, tools, counterparties, limits, duration, resources, escalation, revocation.
Decision and gaps	Desired envelope/RAIL, technical support, permissibility, actual authorization or refusal, accountable decision, blockers, owners, closure evidence, review conditions.
Reuse record	Source pattern, assumptions, qualification scope, applicable requirements/evidence, changed elements, reassessment, expiry or invalidation triggers.

Note. A = Assurance; C = Controls; E = Evidence; RAIL = Risk-Aligned Independence Levels.

Appendix B

Evidence and Authorship Statement

AI-GRACE originated in the authors' professional observations of the challenges organizations face in translating AI objectives and obligations into technical implementation. The framework was conceived and developed as a potential solution to those practical deployment challenges.

AI tools were used as research and editorial assistants to accelerate literature discovery for manual review, manuscript editing and clarification, and adversarial refinement of the framework and its illustrative application. This included challenging assumptions, identifying gaps, and testing the clarity and consistency of the reasoning. The authors directed this process and retained responsibility for the framework's design and substantive decisions. They stand behind the work and take responsibility for its claims.

The manuscript presents a proposed framework and a fictional retail-banking application. The demonstration contains no real client data, and this version reports no organizational experiment or empirical validation of the framework.